

AUDITORIA INTERNA DE TI

Botium Toys

Projeto de portfólio de Cibersegurança — baseado no curso "Play It Safe: Manage Security Risks", parte do Google Cybersecurity Certificate (Coursera)

Alinhado aos princípios de segurança da OWASP e ao NIST Cybersecurity Framework (NIST CSF)

03 de agosto de 2026

INTRODUÇÃO

Este documento é uma auditoria de segurança realizada na empresa fictícia Botium Toys, uma empresa de brinquedos desenvolvida com o propósito da realização da auditoria para meu portfólio de Cibersegurança e do curso "Play It Safe: Manage Security Risks" (Jogar com segurança: Gerenciar Riscos de Segurança). Junto com o Certificado profissional de Cibersegurança do Google no Coursera.

A auditoria visa alinhar as práticas aprendidas no curso citado acima. Utilizando os princípios de segurança da OWASP e NIST.

Cenário

A Botium Toys é uma pequena empresa dos EUA que desenvolve e vende brinquedos. A empresa tem um único local físico, que serve como escritório principal, vitrine e depósito para seus produtos. No entanto, a presença on-line da Botium Toy cresceu, atraindo clientes nos EUA e no exterior. Como resultado, seu departamento de tecnologia da informação (TI) está sob pressão crescente para dar suporte ao mercado on-line em todo o mundo.

A gerente do departamento de TI decidiu que é necessário realizar uma auditoria interna de TI. Ela está preocupada em manter a conformidade e as operações comerciais à medida que a empresa cresce sem um plano claro. Ela acredita que uma auditoria interna pode ajudar a proteger melhor a infraestrutura da empresa e ajudá-la a identificar e reduzir possíveis riscos, ameaças ou vulnerabilidades a ativos críticos. A gerente também está interessada em garantir a conformidade com os regulamentos relacionados ao processamento interno e à aceitação de pagamentos on-line e à realização de negócios na União Europeia (UE).

O gerente de TI começa implementando a estrutura de segurança cibernética do National Institute of Standards and Technology (NIST CSF), estabelecendo um escopo e metas de auditoria, listando os ativos atualmente gerenciados pelo departamento de TI e concluindo uma Avaliação de riscos. O objetivo da auditoria é fornecer uma visão geral dos riscos e/ou multas que a empresa pode sofrer devido ao estado atual de sua postura de segurança.

Sua tarefa é analisar o escopo, as metas e o relatório de avaliação de risco do gerente de TI. Em seguida, realize uma auditoria interna preenchendo uma lista de verificação de controles e conformidade.

OBJETIVOS

Avaliar os ativos existentes e preencher a lista de verificação de controles e conformidade para determinar quais controles e melhores práticas de conformidade precisam ser implementados a fim de melhorar a postura de segurança da Botium Toys.

Ativos atuais

Os ativos gerenciados pelo Departamento de TI incluem:

- Equipamentos locais (*on-premises*) para as necessidades operacionais do escritório
- Equipamentos dos funcionários: dispositivos de usuário final (desktops/laptops, smartphones), estações de trabalho remotas, headsets, cabos, teclados, mouses, estações de acoplamento (*docking stations*), câmeras de vigilância, etc.
- Produtos de loja disponíveis para venda no varejo (presencial e online); armazenados no depósito anexo da empresa
- Gerenciamento de sistemas, softwares e serviços: contabilidade, telecomunicações, banco de dados, segurança, comércio eletrônico e gestão de estoque
- Acesso à Internet
- Rede interna
- Retenção e armazenamento de dados
- Manutenção de sistemas legados: sistemas em fim de vida útil que requerem monitoramento humano

Avaliação de Risco

A tabela a seguir resume os principais riscos identificados, classificados por probabilidade e impacto, para orientar a priorização dos controles.

Ativo / Área	Ameaça / Risco	Probabilidade	Impacto	Severidade
Sistemas legados	Exploração de vulnerabilidades não corrigidas	Alta	Alto	Crítico

Contas de usuário	Acesso indevido por ausência de privilégio mínimo	Alta	Médio	Alto
Dados de cartão de pagamento	Vazamento de dados (não conformidade PCI DSS)	Média	Alto	Alto
Dados pessoais de clientes na UE	Multas por não conformidade com o GDPR	Média	Alto	Alto
Continuidade operacional	Indisponibilidade por ausência de DRP e backups	Média	Alto	Alto
Endpoints	Infecção por malware (sem AV/EDR ativo)	Alta	Médio	Alto

CATEGORIAS DE CONTROLES

Apos analise da auditoria a Botium Toys precisará cumprir as seguintes normas:

Regulamento Geral sobre a Proteção de Dados (GDPR)

Como a Botium Toys pretende se expandir para oferecer serviços e lidar com dados de clientes no exterior, a conformidade com o GDPR é um requisito para o tratamento de informações financeiras e pessoais de clientes na União Europeia.

Padrão de segurança de Dados da Indústria de Cartões de pagamento (PCI DSS)

O PCI DSS é um padrão internacional de segurança destinado a garantir que as organizações que armazenam, aceitam, processam e transmitem informações de cartão de crédito o façam em um ambiente seguro.

A Botium Toys deve cumprir o PCI DSS, pois aceita pagamentos online e presenciais, além de armazenar e processar dados de cartão de crédito de clientes em escala internacional

O impacto do não cumprimento desta norma é severo: multas mensais (variando de 5.000 a 100.000 USD), custos de auditorias forenses após uma violação de dados, restrições impostas pelas bandeiras de cartão, danos à reputação da marca e possíveis custos com processos judiciais em caso de violação de dados.

Controles de Sistema e Organização (SOC tipo 1, SOC tipo 2)

Eles são utilizados para avaliar a conformidade financeira e os níveis de risco de uma organização. Também abrangem confidencialidade, privacidade, integridade, disponibilidade, segurança e a proteção geral dos dados. Falhas de controle nessas áreas podem levar a fraudes.

A Botium Toys precisa estabelecer e manter controles adequados de acesso de usuários para o pessoal interno e externo (fornecedores terceirizados), a fim de mitigar riscos e garantir a segurança dos dados.

Lista de Verificação de Controles e Conformidade

Consolidação dos controles avaliados na auditoria, seu status atual, a recomendação correspondente e a prioridade de implementação.

Controle	Categoria	Status Atual	Recomendação	Prioridade
Privilegio mínimo e segregação de funções	Controle de Acesso	Não implementado	Revisar permissões de todos os usuários e aplicar controle de acesso baseado em função (RBAC)	Crítica — imediato
Plano de recuperação de desastres (DRP)	Continuidade	Não implementado	Criar e testar plano de recuperação de desastres e continuidade de negócio	Crítica — imediato
Políticas de senha e gestão de contas	Controle de Acesso	Inconsistente	Formalizar política (complexidade, MFA, rotação, desativação de contas inativas)	Crítica — imediato
Sistema de Detecção de Intrusão (IDS)	Detecção	Não implementado	Implantar IDS/IPS com monitoramento contínuo	Crítica — imediato
Criptografia em transações on-line	Proteção de Dados	A verificar	Garantir TLS 1.2+ em todo o tráfego do site de e-commerce	Crítica — imediato
Backups	Continuidade	Não implementado	Implementar rotina de backup automatizado e testes de restauração	Crítica — imediato

Software antivírus / EDR	Proteção de Endpoint	Não implementado	Implantar solução de antivírus/EDR em todos os endpoints	Crítica — imediato
Sistema de gerenciamento de senhas	Controle de Acesso	Não implementado	Adotar gerenciador de senhas corporativo	Crítica — imediato
Conformidade com GDPR	Regulatório	Parcial	Mapear dados pessoais de clientes da UE e formalizar políticas de tratamento	Alta — 30–60 dias
Conformidade com PCI DSS	Regulatório	Parcial	Validar escopo PCI e segmentar a rede de pagamento	Alta — 30–60 dias
Diretrizes SOC 1 / SOC 2	Governança	Parcial	Formalizar controles de acesso de terceiros e fornecedores	Média — 60–90 dias
Sinalização de segurança/alarme	Controle Físico	Não implementado	Instalar placas indicando a empresa de segurança/alarme em áreas restritas	Baixa — futuro

Mapeamento aos Controles do NIST CSF

As constatações da auditoria foram organizadas de acordo com as cinco funções centrais do NIST Cybersecurity Framework, para orientar a priorização e a governança do plano de ação.

Função NIST CSF	Achados relacionados
Identify (Identificar)	Inventário de ativos de TI; avaliação de risco por ativo e por ameaça
Protect (Proteger)	Privilegio mínimo e segregação de funções; políticas de senha e MFA; gerenciador de senhas; criptografia das transações on-line; controles de acesso de terceiros
Detect (Detectar)	Sistema de Detecção de Intrusão (IDS); software antivírus/EDR
Respond (Responder)	Políticas e procedimentos formais, incluindo playbooks operacionais de resposta a incidentes
Recover (Recuperar)	Plano de recuperação de desastres (DRP); rotina de backups e testes de restauração

Memorando para as partes interessadas

PARA: Gerente de TI, Partes Interessadas

DE: Jose Italo

DATA: 31/08/2026

ASSUNTO: Auditoria Interna de TI — Recomendações e Descobertas

Prezados colegas,

Por favor, analisem as informações a seguir referentes ao escopo, objetivos, resumo e recomendações da auditoria interna da Botium Toys.

Escopo

Os seguintes sistemas estão incluídos no escopo: detecção de ameaças em endpoints, firewalls, sistema de detecção de intrusão e ferramenta de gerenciamento de eventos e informações de segurança (SIEM). Os sistemas serão avaliados quanto a:

- Permissões de usuários atuais
- Controles atualmente implementados
- Inventário de tecnologias e ativos atuais, abrangendo tanto hardware quanto acesso aos sistemas

Objetivos

- Atender à estrutura NIST CSF
- Implementar o conceito de privilégio mínimo
- Estabelecer políticas e procedimentos, incluindo os playbooks operacionais

Constatações Críticas (devem ser tratadas imediatamente)

- Princípio do privilégio mínimo e segregação de funções
- Planos de recuperação de desastres
- Políticas de senhas, controles de acesso e gerenciamento de contas
- Sistema de Detecção de Intrusão (IDS)
- Criptografia (transações seguras em sites)
- Backups
- Software antivírus (AV)
- Implementação de um sistema de gerenciamento de senhas

É necessário desenvolver e implementar políticas para atender aos requisitos do PCI DSS e do GDPR, além das diretrizes SOC 1 e SOC 2 (detalhamento completo na lista de verificação de controles e conformidade, seção anterior).

Controles Físicos a Considerar Futuramente

Após a resolução das constatações críticas:

- Sinalização indicando a empresa de segurança/alarme para áreas restritas

Recomendações

Recomenda-se tratar prontamente as constatações críticas relacionadas à conformidade com PCI DSS e GDPR, uma vez que a Botium Toys aceita pagamentos on-line e está expandindo suas operações para oferecer serviços e processar dados de clientes no exterior, inclusive na União Europeia. As diretrizes SOC 1 e SOC 2 relacionadas às políticas de acesso do usuário devem ser utilizadas para alinhar-se ao objetivo da auditoria, adaptando-se ao conceito de privilégio mínimo para desenvolver as políticas e os procedimentos necessários à conformidade.

A implementação de planos de recuperação de desastres e backups, somada à integração de sistemas IDS e software antivírus aos sistemas atuais, permitirá auxiliar na detecção de intrusões e na identificação e mitigação de riscos potenciais — levando em conta a existência de sistemas legados que requerem monitoramento e intervenção manuais.

Atenciosamente,

Jose Italo

Auditor Interno de TI